

《信息对抗技术》

实验五：X-Scan 的使用

姓名：张昌源

学号：2313177

实验日期：2026 年 4 月 22 日

目录

1	实验目的	2
2	实验环境	2
3	实验原理	2
4	实验过程	2
4.1	软件准备与启动	2
4.2	扫描参数配置	4
4.3	执行扫描并生成报告	7
5	实验结果与分析	9
5.1	445/tcp 端口开放与 SMB 相关风险	10
5.2	139/tcp 的 NetBIOS 信息泄露	10
5.3	135/tcp 的 RPC 服务暴露	11
5.4	123/udp 的 NTP 服务提示	11
5.5	结果总体评价	11
6	安全隐患与加固建议	11
7	实验总结	12

1 实验目的

1. 熟练掌握 X-Scan 扫描器的基本使用方法，了解其扫描参数配置过程。
2. 通过对本机系统进行扫描，识别开放端口、共享服务以及可能存在的安全隐患。
3. 结合扫描报告，对 Windows XP 主机的服务暴露、信息泄露与潜在风险进行分析，并提出加固建议。

2 实验环境

- 操作系统：Windows XP
- 扫描软件：X-Scan v3.3-cn
- 扫描对象：本机 localhost
- 报告格式：HTML

3 实验原理

X-Scan 是一款面向 Windows 平台的综合漏洞扫描工具，能够通过插件化方式对目标主机进行端口探测、服务识别、NetBIOS 信息收集、远程操作系统识别以及基于漏洞脚本的安全检查。其基本工作流程可概括为：

1. 对目标主机进行连通性探测与端口扫描，判断主机是否存活以及存在哪些开放端口；
2. 根据开放端口识别可能运行的服务，例如 SMB、RPC、NetBIOS、NTP 等；
3. 调用相应插件收集主机系统信息、共享信息、注册表信息或已知漏洞特征；
4. 将扫描结果按照设定格式输出为报告，便于后续分析和修补。

在本实验中，目标设定为 localhost，即扫描本机。实验的重点不是远程渗透，而是通过综合扫描结果观察本机开放服务与配置信息暴露情况，从而分析系统安全隐患。

4 实验过程

4.1 软件准备与启动

首先在宿主机中获取完整的 X-Scan v3.3 工具目录，并将其复制到 Windows XP 实验环境中。经检查，工具目录中包含 xscan_gui.exe、plugins、scripts、CheckHost.dat 及相关依赖动态链接库，说明软件结构完整，可以正常运行。随后双击 xscan_gui.exe 启动图形界面程序。

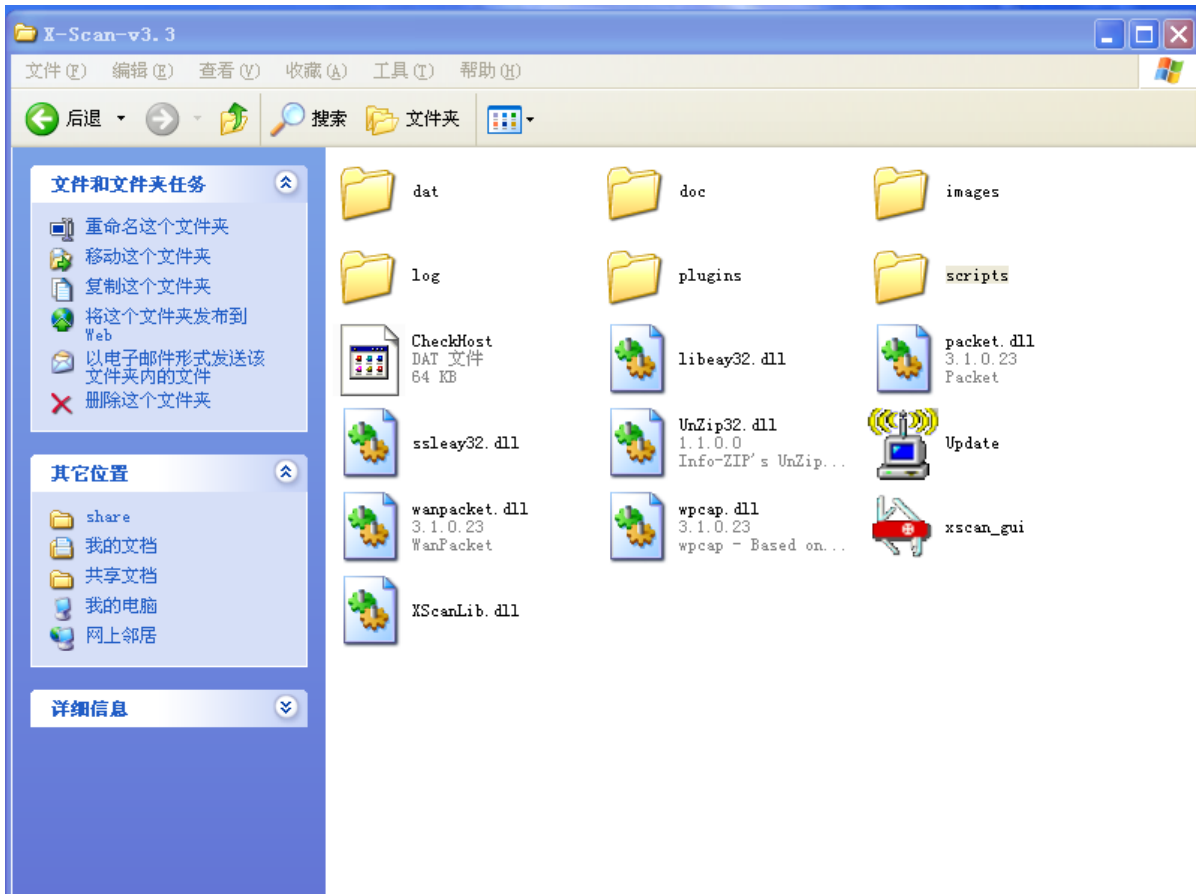


图 1: X-Scan 工具目录

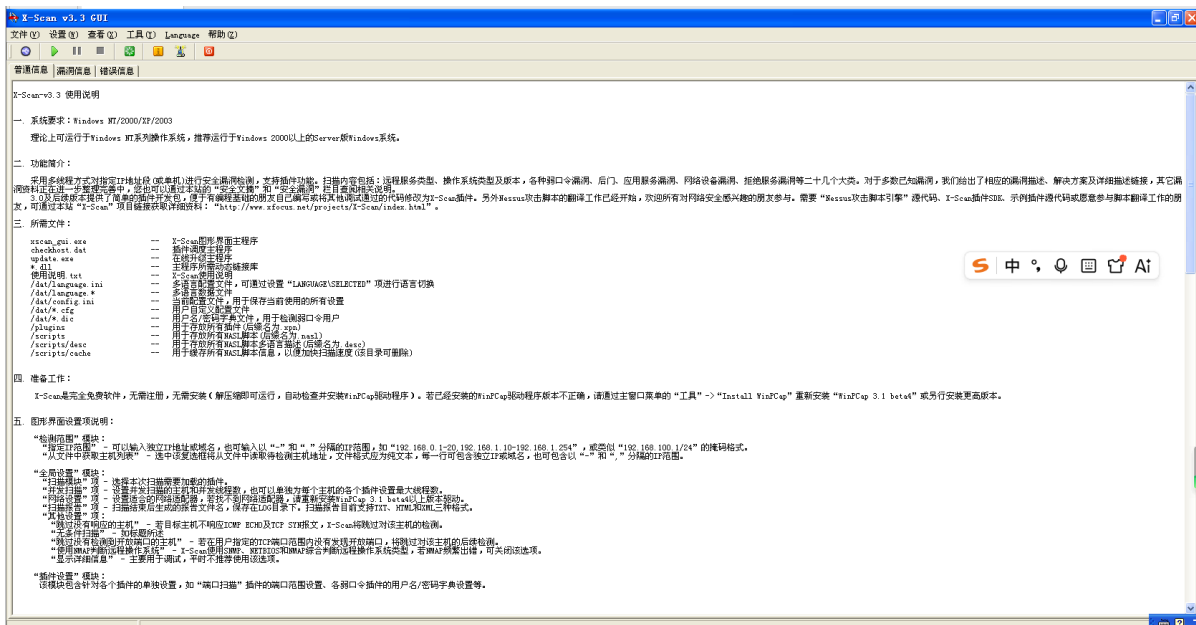


图 2: X-Scan 启动后的主界面说明页

4.2 扫描参数配置

进入“扫描参数”后，首先在“检测范围”中保持默认值 `localhost`，即将本机作为本次扫描目标。随后对全局设置与插件设置进行配置：

- 在“扫描模块”中启用开放服务、NetBIOS 信息、远程操作系统、弱口令尝试以及漏洞检测脚本等项目；
- 在“并发扫描”中保持默认主机数与线程数设置，以兼顾效率与稳定性；
- 在“扫描报告”中将输出格式设置为 HTML，并启用扫描结束后自动生成并显示报告；
- 在“其他设置”中勾选“跳过没有检测到开放端口的主机”“使用 NMAP 判断远程操作系统”等选项；
- 在“端口相关设置”中使用默认端口范围与插件线程设置，保证扫描结果较为完整。

2000以上的Server版Windows系统。

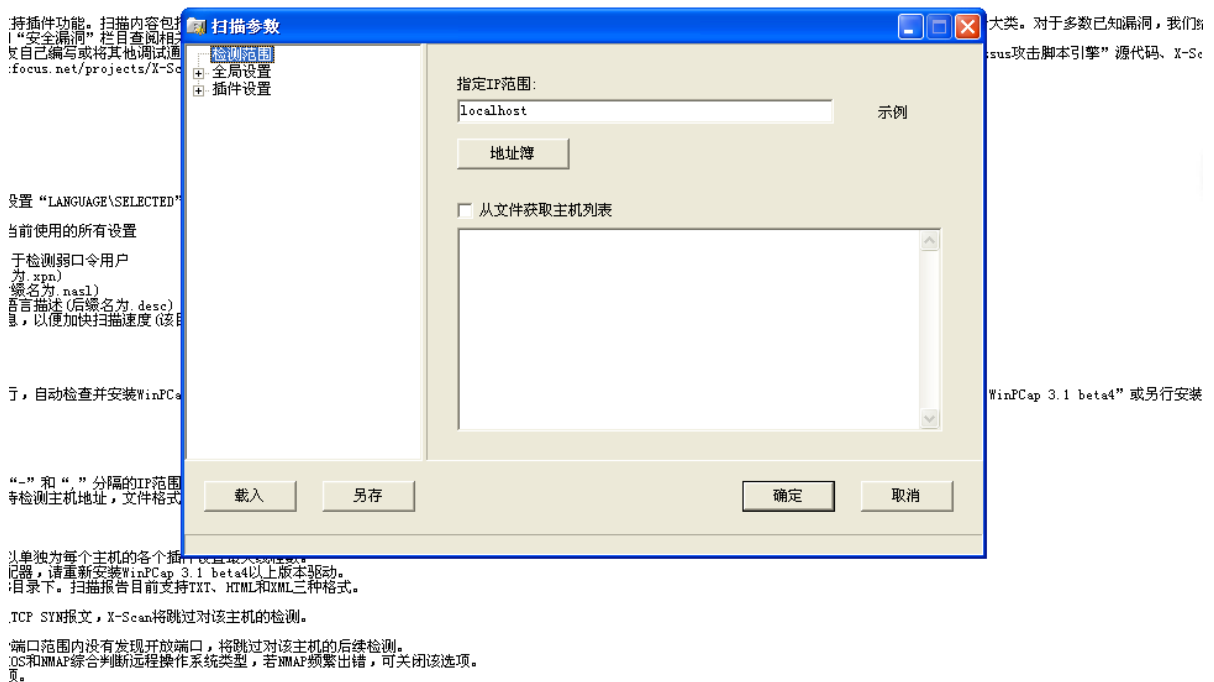


图 3: 检测范围设置为 localhost



图 4: 扫描模块设置

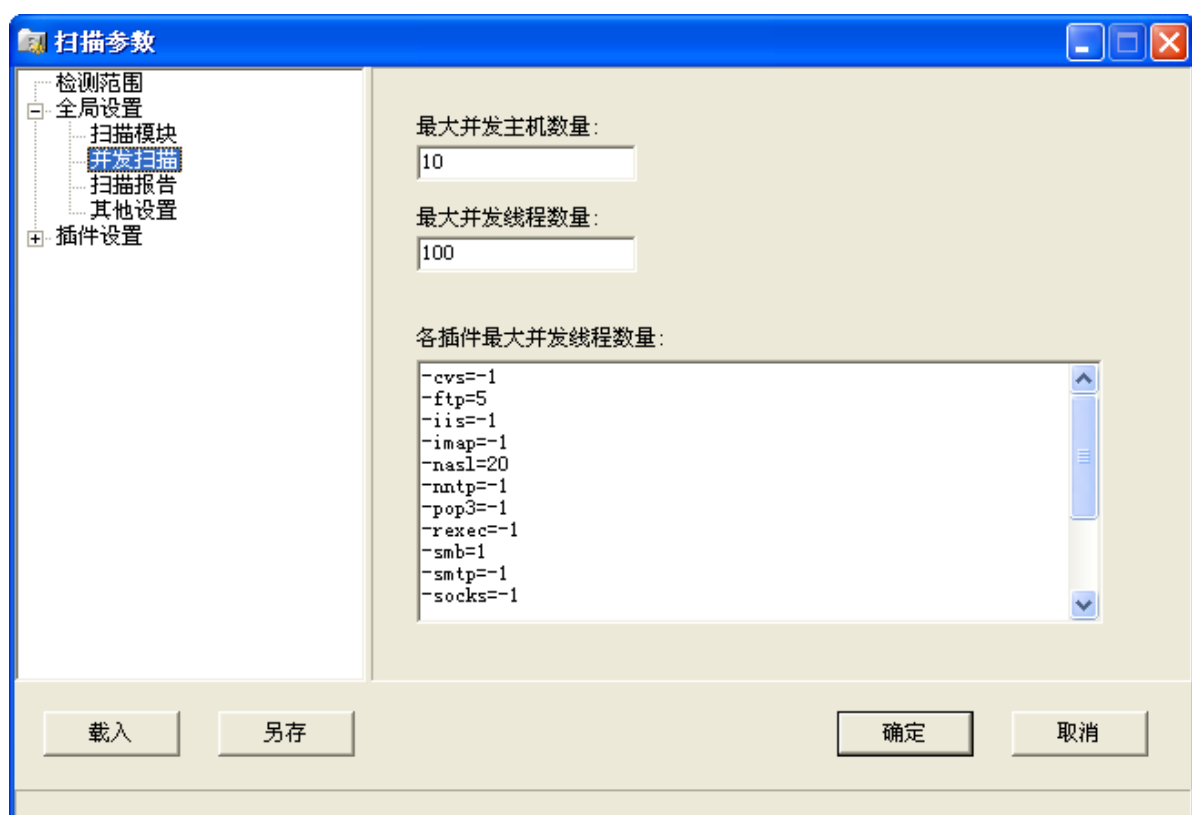


图 5: 并发扫描参数

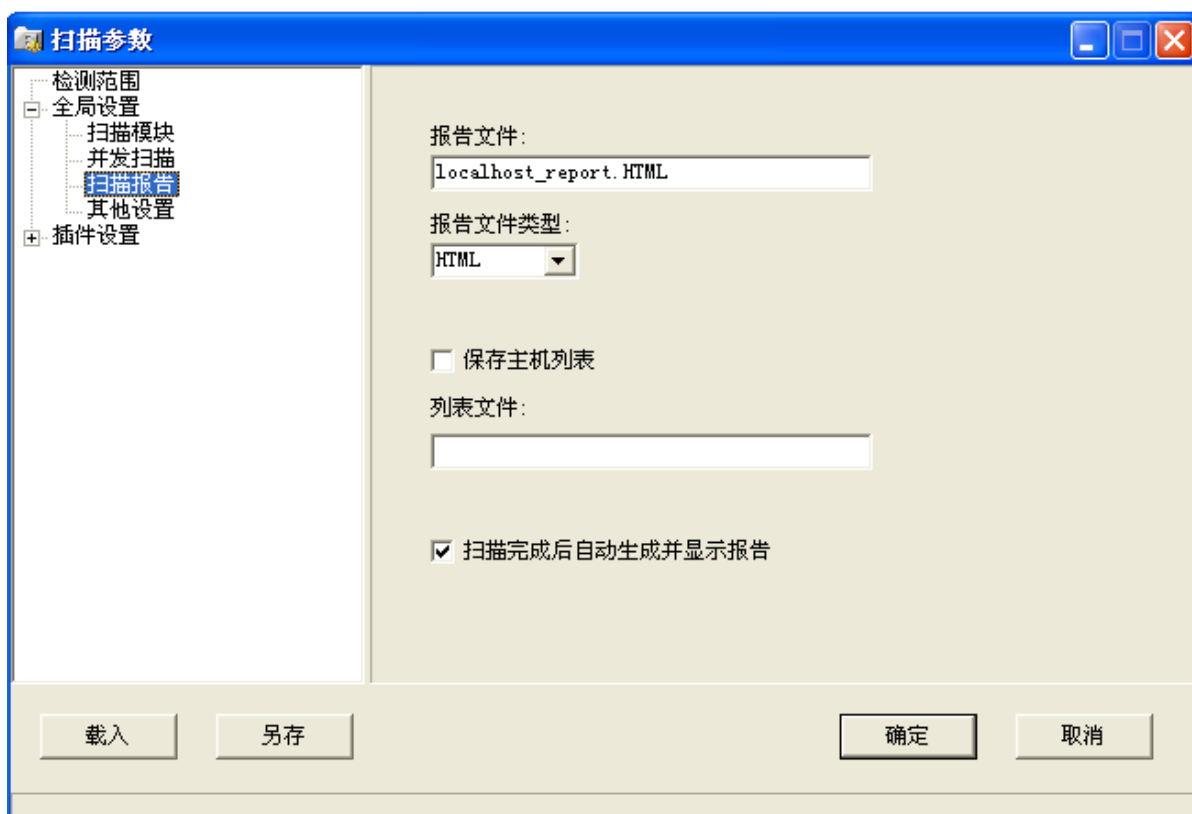


图 6: 扫描报告设置

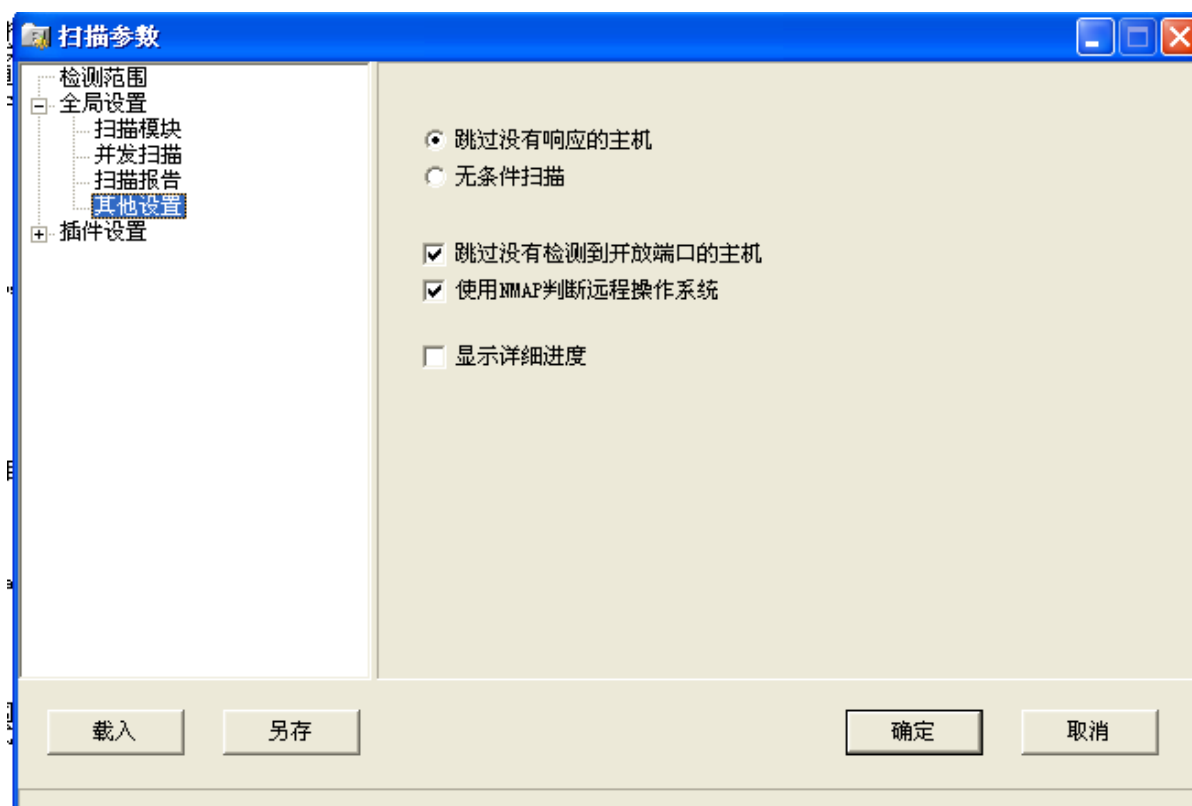


图 7: 其他设置

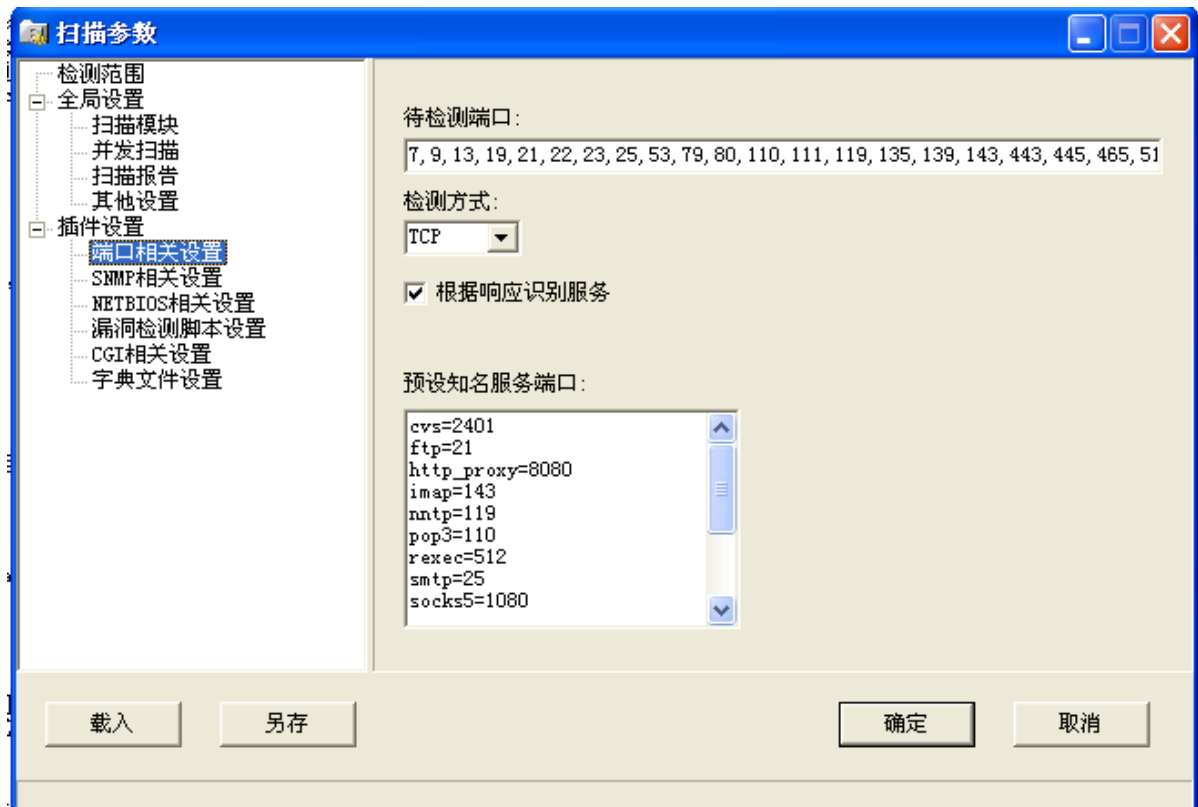


图 8: 插件与端口相关设置

4.3 执行扫描并生成报告

参数设置完成后，返回主界面并点击开始扫描。程序先加载漏洞检测脚本，再依次对本机进行开放服务、NetBIOS、远程操作系统、SMB 与 NTP 等相关项目检测。扫描完成后，X-Scan 自动在 log 目录下生成 localhost_report.HTML 报告文件，并在浏览器中打开显示。

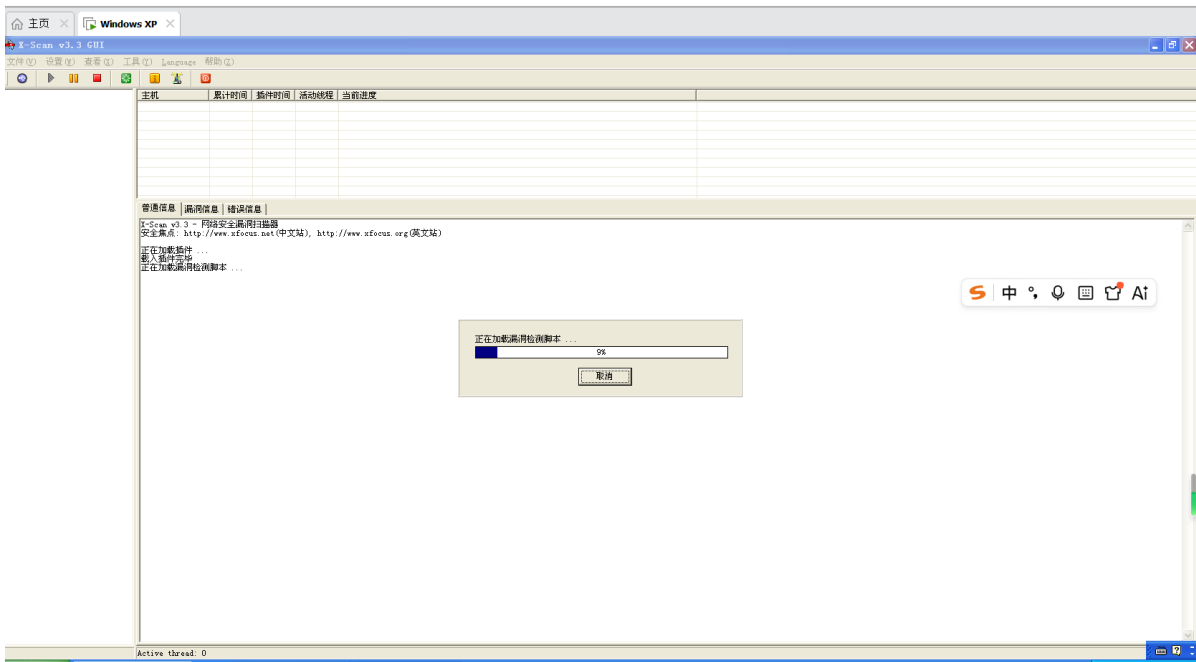


图 9: 加载漏洞检测脚本

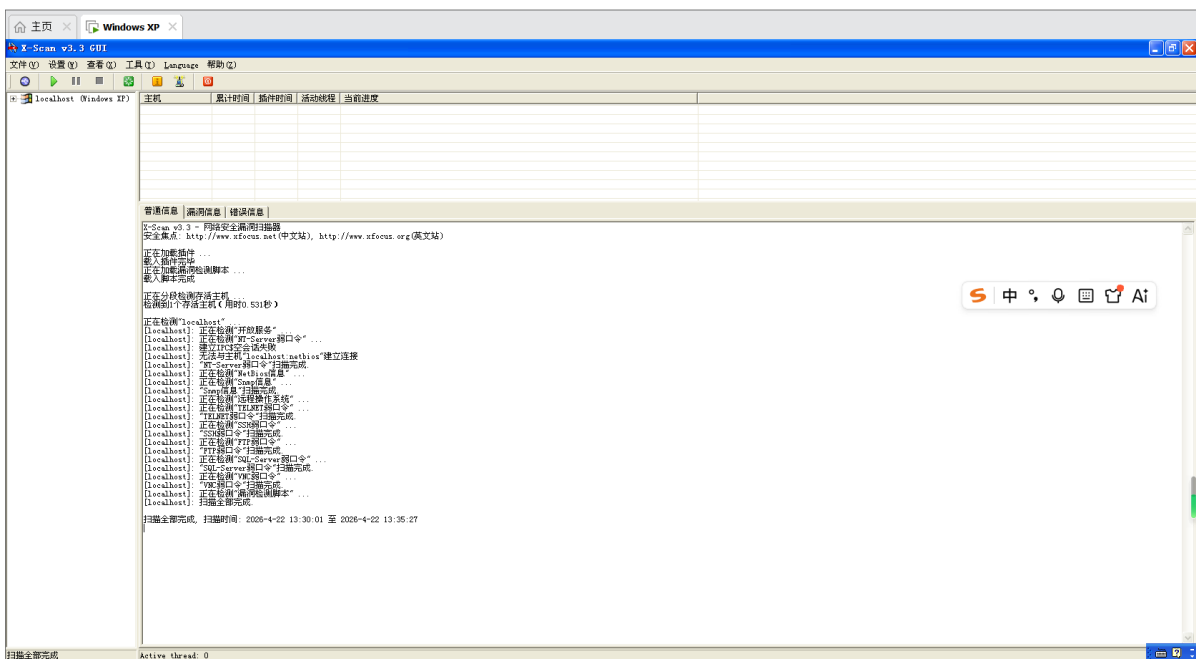


图 10: 扫描过程日志输出

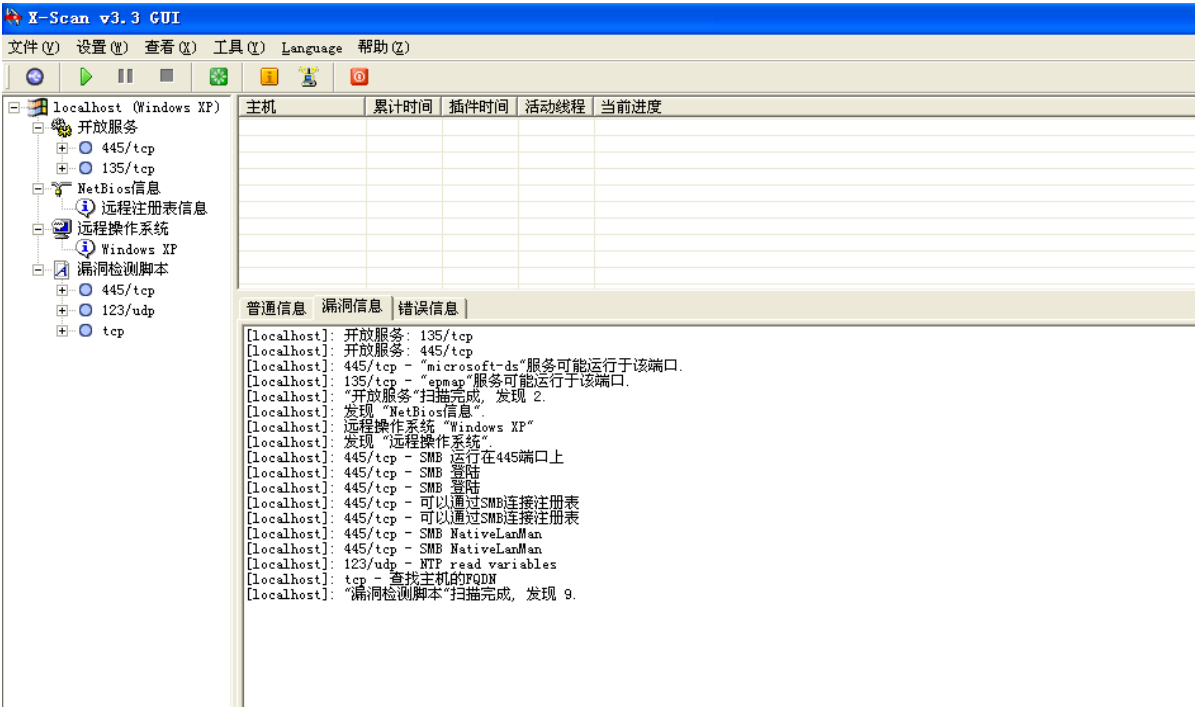


图 11: 扫描完成后的结果树



图 12: HTML 报告总览

5 实验结果与分析

根据 X-Scan 生成的 HTML 报告，本次扫描的总体结果如表 1 所示。

表 1: 扫描结果汇总

项目	结果
存活主机数	1
漏洞数量	0
警告数量	1
提示数量	11
主机识别结果	Windows XP
主机摘要	OS: Windows XP; PORT/TCP: 135, 445

从扫描结果可以看出，本机并未被识别出“可直接确认的高危漏洞”，但发现了 1 条安全警告和 11 条安全提示，说明主机仍然存在较明显的服务暴露与信息泄露风险。结合结果树与 HTML 报告，可归纳出以下几个重点问题。

5.1 445/tcp 端口开放与 SMB 相关风险

报告显示本机开放了 445/tcp，服务被识别为 microsoft-ds。这表明主机启用了 SMB 文件共享相关服务。X-Scan 在该端口上给出了多项提示，包括：

- **开放服务**：说明 445 端口上存在可识别的共享服务；
- **SMB 运行在 445 端口上**：表示系统存在 NetBIOS-less 的 SMB 通信方式；
- **SMB 登陆**：说明扫描脚本尝试通过 SMB 获取共享连接、用户列表及其他信息；
- **可以通过 SMB 连接注册表**：表明远程注册表相关能力存在潜在暴露面；
- **SMB NativeLanMan**：识别出远程系统为 Windows 2000 LAN Manager 风格的 SMB 环境。

445 端口是 Windows 文件共享环境中的关键端口，其开放往往意味着共享、用户名、主机角色等信息可能被进一步枚举。即使没有直接出现“高危漏洞”，仅凭该端口暴露也会显著增加攻击面。

5.2 139/tcp 的 NetBIOS 信息泄露

本次扫描中唯一的“安全警告”落在 139/tcp，服务为 netbios-ssn。从报告可以看出，扫描器通过该项收集到了大量注册表与系统信息，包括：

- 系统名称为 Microsoft Windows XP；
- 当前版本为 5.1，构建号为 2600；
- 系统已安装 Service Pack 3；

- 系统根目录为 C:
WINDOWS;
- 机器名、默认用户名、部分注册表配置等信息可被读取。

上述信息本身虽然不一定直接形成漏洞利用链，但会帮助攻击者准确判断目标系统类型、补丁状态与潜在攻击入口，因此属于典型的信息泄露问题。在真实网络环境中，这类信息泄露通常是后续攻击与横向移动的重要前置信息。

5.3 135/tcp 的 RPC 服务暴露

报告显示本机还开放了 135/tcp，服务被识别为 epmap。这说明主机启用了 RPC Endpoint Mapper 服务。135 端口是 Windows 系统远程调用的重要入口，在历史上长期属于安全关注重点。虽然本次扫描未给出明确漏洞结论，但该端口的对外暴露仍然意味着远程管理与调用接口存在可探测面，应在防火墙与系统配置中进行严格控制。

5.4 123/udp 的 NTP 服务提示

报告还提示本机存在 123/udp 服务，对应 ntp。这说明时间同步服务在运行。与 SMB、NetBIOS、RPC 相比，NTP 本身风险较低，但其开放依然会暴露服务指纹与系统行为信息，因此在安全分析中通常作为低风险提示项记录。

5.5 结果总体评价

综合来看，本次扫描虽然未检出确定性的高危漏洞，但已经清晰反映出该 Windows XP 主机存在如下问题：

1. 共享服务端口 445/tcp 暴露，增加了 SMB 枚举与共享探测风险；
2. NetBIOS/139 端口暴露导致较多系统与注册表信息泄露；
3. 135/tcp 的 RPC 服务对攻击者提供了额外探测入口；
4. 老旧系统本身安全基线较低，一旦进一步接入复杂网络环境，风险将明显上升。

因此，可以认为本机当前的安全问题主要集中在 **服务暴露过多、信息泄露较明显、系统版本老旧**这三个方面。

6 安全隐患与加固建议

结合本次扫描结果，可提出如下整改建议：

1. **关闭不必要的共享服务**。若实验主机不需要文件共享，应关闭 445/tcp 相关 SMB 服务，减少共享暴露面。

2. **限制 NetBIOS over TCP/IP**。若无特殊需求，应关闭 NetBIOS 服务或通过主机防火墙限制 139/tcp 的访问。
3. **严格控制 RPC 端口**。对 135/tcp 进行访问控制，仅允许可信环境下的必要管理通信。
4. **减少信息泄露**。禁止匿名会话与不必要的远程注册表访问，避免系统版本、用户名、注册表配置等信息被枚举。
5. **加强补丁和基线配置**。Windows XP 已属于老旧系统，应尽可能减少联网使用场景，在实验环境外不建议继续作为生产系统使用。
6. **启用主机防火墙**。对 123/udp、135/tcp、139/tcp、445/tcp 等端口进行入站访问限制，只保留确有必要的服务。

7 实验总结

通过本次实验，我完成了 X-Scan v3.3 的安装、参数配置、脚本加载、目标扫描以及 HTML 报告分析全过程，掌握了综合扫描器的基本使用方法。实验结果表明，即使在未发现“明确高危漏洞”的情况下，主机依然可能因为开放端口、共享服务、NetBIOS 枚举和注册表信息泄露而暴露出较大的潜在风险。

本次实验进一步说明：系统安全并不只体现在是否存在“可利用漏洞”，还体现在服务是否最小化暴露、端口是否受控、共享与注册表访问是否受到限制等方面。对于 Windows XP 这类老旧系统而言，及时关闭不必要服务、限制敏感端口以及减少信息泄露，是提升主机安全性的重要措施。